Name: Muhammad Usama Bilal

Roll Number :CSI-B1-460

INSTRUCTOR: MUHAMMAD SAAD

Date: 23-3-206

TASK 01: SMB Enumeration & Exploitation

The purpose of this lab is to explore how attackers exploit the SMB protocol to move within an internal network after gaining initial access. The task includes scanning SMB services, identifying shared resources, accessing them, and analyzing network traffic.

➢ Overview of SMB Protocol

SMB (Server Message Block) is a network communication protocol mainly used in Windows systems for:

- File sharing
- Printer sharing
- Communication between devices in a LAN

Due to its widespread use, SMB is a common target for attackers during internal network attacks.

➢ Comparison: Port 139 vs Port 445

Port 139 (NetBIOS-based SMB)

- Works using NetBIOS
- Older communication method
- Slower and less secure

Port 445 (Direct SMB)

- Works directly over TCP/IP
- Faster and more efficient
- Used in modern systems
  Modern networks prefer **port 445** because it provides better performance and improved security.

➢ **Famous SMB Attack: WannaCry**

One of the most well-known SMB-based attacks is **WannaCry ransomware (2017)**.

- Exploited vulnerability in SMBv1
- Spread automatically across systems
- Encrypted user files and demanded ransom

Why SMBv1 was vulnerable

- No encryption
- Weak protocol design
- Allowed remote code execution

Is SMB Still Dangerous Today?

Improvements:

- SMBv2 & SMBv3 are more secure
- SMBv1 is disabled by default
- Firewalls block external access

Still risky if:

- Old systems are used
- Weak passwords exist
- Shared folders are open

Conclusion: SMB remains a threat in poorly configured environments.

🛠 Tools Used

- Kali Linux
- Nmap

- smbclient
- Wireshark

➢ SMB Port Scanning (Nmap)

The target machine was scanned using Nmap to identify SMB services.

```
┌──(usama㉿kali)-[~]
└─$ nmap -p 139,445 -sV 192.168.88.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-23 08:31 EDT
Nmap scan report for 192.168.88.129
Host is up (0.0040s latency).

PORT    STATE SERVICE       VERSION
139/tcp open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds?
MAC Address: 00:0C:29:76:59:0D (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.93 seconds
```

➢ SMB Version Detection

To determine SMB versions:

```
┌──(usama㉿kali)-[~]
└─$ nmap --script smb-protocols -p 445 192.168.88.129
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-23 08:35 EDT
Nmap scan report for 192.168.88.129
Host is up (0.00075s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:76:59:0D (VMware)

Host script results:
| smb-protocols:
|   dialects:
|     2:0:2
|     2:1:0
|     3:0:0
|     3:0:2
|_    3:1:1

Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds
```

- **SMB Share Enumeration**

The available shared folders were listed using:

```
┌──(usama㉿kali)-[~]
└─$ nmap --script smb-enum-shares -p445 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 08:32 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0019s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:F8:5F:5E (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-enum-shares:
|   account_used: <blank>
|   \\192.168.56.102\ADMIN$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.102\IPC$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|   \\192.168.56.102\opt:
|     Type: STYPE_DISKTREE
|     Comment:
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.102\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: <none>
|   \\192.168.56.102\tmp:
```

- **Accessing Shared Resources**

The shared folder was accessed using:

```
┌──(usama㉿kali)-[~]
└─$ smbclient -L //192.168.56.102 -N
Anonymous login successful

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        tmp             Disk      oh noes!
        opt             Disk
        IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
        ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

        Server               Comment
        ---------            -------

        Workgroup            Master
        ---------            -------
        WORKGROUP            METASPLOITABLE
```

- **Network Traffic Analysis (Wireshark)**

Wireshark was used to monitor SMB traffic.

Filter applied:

smb | smb2

No.	Time	Source	Destination	Protocol	Length	Info
3	86.370403460	192.168.56.102	192.168.56.255	BROWSER	286	Local Master Announcement METASPLOITABLE, Workstation, Server, Print Queue Serv
4	86.370931599	192.168.56.102	192.168.56.255	BROWSER	257	Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum
33	586.926760914	192.168.56.102	192.168.56.255	BROWSER	286	Local Master Announcement METASPLOITABLE, Workstation, Server, Print Queue Serv
34	586.928783726	192.168.56.102	192.168.56.255	BROWSER	257	Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum

TASK 02: PRACTICAL LATERAL MOVEMENT

What is Lateral Movement?

Lateral movement is a technique where an attacker moves from one compromised system to other systems within the same network to expand access.

Purpose of Lateral Movement

Attackers perform lateral movement to:

- Access additional machines
- Gather sensitive data
- Increase control over the network

Is Pivoting Required?

No — pivoting is not required here because:

- All systems are in the same network
- Direct communication is possible

Pivoting is only needed in segmented networks.

How Lateral Movement Works

1. Initial system is compromised
2. Credentials are obtained
3. Credentials are reused on another system
4. Access is successfully gained

Services Used for Movement

- SMB
- SSH
- RDP

Horizontal vs Vertical Movement

Horizontal Movement

- Moving between systems
- Same privilege level

Vertical Movement

- Gaining higher privileges
- Example: User → Admin

Both are important in real attacks

Artifacts (Evidence Left Behind)

During lateral movement:

- Login logs
- Network activity
- Authentication records

These help in detection of attacks

Practical Credential Reuse

The discovered credentials were reused:

Username:usama

Password:kali9780

Accessing Second System

Files and directories were explored to find:

- Configuration files
- Credentials
- Logs

How SMB Helped in Lateral Movement

SMB enumeration allowed identification of shared folders and exposed sensitive credentials. These credentials were reused to access another system, enabling lateral movement within the network.

Conclusion

This lab demonstrates how attackers can exploit SMB misconfigurations to:

- Discover sensitive data
- Reuse credentials
- Move laterally across systems

It highlights the importance of:

- Strong passwords
- Secure configurations
- Disabling SMBv1
- Restricting access to shared resources